CARTILHA

Orientações sobre incidentes de segurança



Coautora: Camila Catanho

MASCARELLO HAUS
CONSULTORIA E ASSESSORIA JURÍDICA

ORIENTAÇÕES SOBRE INCIDENTES DE SEGURANÇA

AUTORES:
CAMILA CATANHO

REVISÃO TÉCNICA:
MIRATAIRA HAUS

PROJETO GRÁFICO:
TEMPERO PROPAGANDA



O que você vai entender com essa cartilha:

- A importância da proteção dos dados pessoais;
- Aspectos gerais da lei geral de proteção de dados pessoais (LGPD):
  - Por que uma lei geral?
  - O “bê-a-bá” da Lei: definições, principais conceitos, princípios, bases legais, atores envolvidos, direitos dos titulares.

Segurança da informação

A missão da segurança da informação é proteger os dados, estejam eles em meio eletrônico ou físico, de ameaças existentes através de um conjunto de práticas, controles, políticas, procedimentos e técnicas, aplicadas a softwares, hardwares e a ambientes físicos em que se encontram os dados.

As informações são ativos da empresa e devem ser resguardadas, especialmente em um mundo datificado no qual a quantidade de dados de uma organização e a capacidade de processamento são grandes diferenciais competitivos que podem ser determinantes para a sobrevivência do negócio. Além disso, dados relativos à própria empresa são em sua grande parte sigilosos e se vasados podem gerar enormes prejuízo.

Em diversos setores, como por exemplo bancário, saúde e defesa, temos ainda as questões legais e regulamentares que exigem ações para proteger as informações que possuem e, atualmente, com a publicação da lei geral de proteção de dados - LGPD (lei 13.709/2018), todas as empresas que tratam dados de pessoas físicas tem que adotar medidas de segurança para resguardá-los.

Assim, não há dúvidas de que todo empresário deve se preocupar e investir em segurança da informação para minimizar ao máximo o risco e garantir a continuidade das operações da organização.

Uma boa política de segurança da informação visa garantir a preservação desses 5 pilares:

1. **Confidencialidade:** os dados devem ser protegidos contra acesso de pessoas não autorizadas, o que pode ser feito através do controle de acesso, com senhas, autenticação de dois fatores, biometria ou outros meios e também com o uso de criptografia

e métodos de anonimização;

2. Integridade: as informações devem ser íntegras, ou seja, devem corresponder exatamente as informações coletadas, sem alteração, adulteração ou corrupção não autorizada. Assim, em sistemas computacionais é importante que o banco de dados não permita alteração de qualquer usuário e também guarde tanto o registro de quem fez a alteração quanto quais foram as modificações realizadas;

3. Disponibilidade: os dados devem estar disponíveis para o acesso de todas as pessoas autorizadas quando necessário. Dessa forma é importante ter backups periódicos dos dados, bem como processos de recuperação de backups periódicos, para evitar a perda dos dados em caso de acidente ou ataque. Além disso, também podem ser criados sistemas redundantes, ou seja, ter dois ou três sistemas que fazem a mesma coisa, especialmente as atividades críticas, pois se um falhar isso não irá afetar a operação e a continuidade do negócio;

4. Autenticidade: assegura que a fonte dos dados realmente é a informada. Normalmente o método oficial de autenticação aceito pela lei são os certificados digitais, emitidos por autoridades certificadoras credenciadas, utilizam criptografia assimétrica para garantir a autoria do documento e também sua integridade, uma vez que não será possível modificar um documento assinado com a tecnologia sem que tal alteração seja identificada. Entretanto existem outros métodos de garantir a autenticidade, tais como uso de geolocalização, fotos, hahs e logs, sendo que a lei atualmente reconhece esses meios alternativos, conforme a lei 14.063/2020;

5. Irretratabilidade ou não repúdio: não deve

ser possível a pessoa ou entidade negar a autoria da informação fornecida ou ato praticado, assim a empresa deve ter formas de provar o que foi feito ou informado dentro de um sistema.

O que é um incidente de segurança?



Um incidente de segurança da informação consiste na ocorrência de um evento, seja acidental ou proposital, causado por um ataque, confirmado ou sob suspeita, que afete significativamente a segurança da informação, ou seja, comprometa um dos pilares acima mencionados e tenha probabilidade de comprometer também as operações do negócio, conforme previsto na ISO/IEC 27.000:2014 que trata da gestão da segurança da informação.

Ou seja, nem toda ocorrência de erro nos sistemas da empresa caracterizam um incidente de segurança, pequenas falhas que não comprometem o negócio e nem afetam a política de segurança. Tais eventos devem ser corrigidos sob pena de se tornarem problemas maiores e causarem um incidente, mas não é necessário realizar todas as medidas, comunicações e salvaguardas adotadas na resposta de um incidente.

Existem vários tipos de incidentes de segurança da informação, sendo os mais relevantes:

ATAQUES CIBERNÉTICOS:

São ataques que ocorrem por meio de sistemas computacionais, através da exploração de vulnerabilidades identificadas, como por exemplo:

1. **Ransomware:** um dos ataques mais usados por blackhacks para extorquir dinheiro de suas vítimas. Neste ataque o hacker invade o sistema da empresa através de um anexo de e-mail, arquivo ou link infectado ou ainda explorando alguma vulnerabilidade encontrada no sistema. Após a invasão o criminoso criptografa todos os arquivos da organização, tornando-os inutilizáveis, ou bloqueia a tela de acesso ao sistema chamado "lock-screen", e manda uma mensagem exigindo o pagamento de um resgate para resolver o problema e não vazar os dados obtidos;



2. **DoS (Denial of Service):** é um ataque de negação de serviço, nesse tipo de ataque o sistema é sobrecarregado causando uma falha e impedindo o seu acesso por usuários legítimos, as formas mais comuns de implementação deste tipo de ataque é através da sobrecarga de tráfego, quando um site recebe mais acessos que a banda do site suporta, por

meio da exaustão de recursos, como memória por exemplo. É um ataque muito utilizado por hacktivistas, hackers que praticam o ciberativismo utilizando sua habilidade para promover causas sociais, políticas ou ideológicas;



3. **Injeção de SQL:** forma de ataque em aplicativos web que utilizam SQL em seu banco de dados. O invasor insere códigos SQL em um formulário ou campos de entrada e, quando existe vulnerabilidade no sistema, o sistema interpreta este código como pertencente ao sistema de banco de dados, assim o usuário passa então a poder fazer qualquer requisição diretamente do banco de dados, ou seja, pode ter acesso aos dados ali armazenados, pode alterá-los ou usar essa técnica para fazer um ataque DoS, explicado anteriormente;



4. **Pishing:** esse tipo de ataque usa engenharia social, os criminosos estudam a vítima ou grupo alvo de pessoas e usam seus hábitos, expectativas, confiança e ignorância para induzi-las a erro e fazer com que forneçam informações ou instalem algo que irá gerar uma vulnerabilidade no sistema capaz de permitir a entrada do atacante. O pishing é usado desde para promover fraudes bancárias pequenas até para ataques maiores de ransonwere.

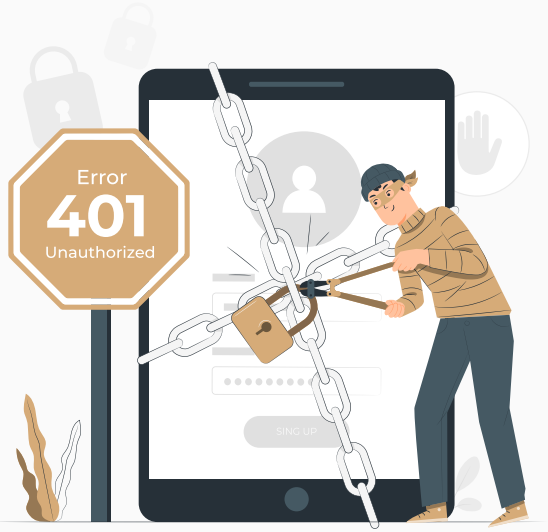


1. Ocorridos em território nacional;
2. Com objetivo de oferecer bens ou serviços a pessoas localizadas no Brasil;
3. Coletados no Brasil, ou seja, cujos titulares - brasileiros ou não - estejam no Brasil no momento da coleta.

ACESSO NÃO AUTORIZADO

Além de ataques cibernéticos, o erro humano, processos organizacionais mal feitos ou violações aos espaços físicos onde os dados estão localizados também podem levar a incidentes relacionados a acesso não autorizado. Podemos citar colaboradores que deixam o computador logado e vão almoçar, ausência de técnicas de bloqueio de envio ou salvamento de arquivos dos servidores, descarte ou doação de equipamentos sem limpar corretamente o disco rígido e deletar os arquivos e salas de arquivo sem qualquer tranca ou controle de acesso

como alguns eventos que podem gerar acesso não autorizado a dados, porém não relacionados diretamente a problemas de cibersegurança.



VAZAMENTO DE DADOS:

Assim como no caso de acesso não autorizado, os problemas com a guarda de ambientes físicos, processos organizacionais equivocados e principalmente erro humano é um grande fator de vazamento de dados, por exemplo: funcionários usam equipamentos pessoais para trabalho, especialmente celulares e acabam ficando com dados da empresa quando saem do emprego; uso de folhas de rascunho com dados; portaria sem o devido controle, entre outros problemas.



PERDA OU ROUBO DE DISPOSITIVO:

Apesar dos dispositivos geralmente serem

protegidos por senhas de acesso existem softwares capazes de “quebrar” a senha, assim todo caso de perda e roubo é um incidente.



Segurança da informação e LGPD. Todo incidente de segurança é uma violação à Lei Geral de Proteção de Dados?

A LGPD dá grande importância a segurança, tanto que a coloca como princípio a ser seguindo em toda e qualquer atividade de tratamento de dados pessoas, dispondo no art. 6, VIII que deverão ser utilizadas “medidas técnicas e administrativas aptas a proteger os dados pessoais de acessos não autorizados e de situações acidentais ou ilícitas de destruição, perda, alteração, comunicação ou difusão”.

Além disso no art.46 da LGPD novamente é estabelecido que os agentes de tratamento devem adotar medidas de segurança para impedir acessos não autorizados, destruição, perda ou alteração dos dados pessoais, ou seja, violações a confidencialidade, integridade e disponibilidade. Também temos disposições expressas obrigando a adoção de medidas de segurança da informação nos artigos 47 e 49 da LGPD.

No entanto, vale lembrar que nem todo incidente de segurança tem reflexos na LGPD, pois a segurança da informação protege todos os dados da companhia, e não só os dados pessoais, assim somente os incidentes que envolverem dados pessoais deverão

ser considerados para fins de cumprimento de obrigações impostas na LGPD.

Por fim, nem todo incidente implica em violação à LGPD e a aplicação de multa. A lei geral de proteção de dados exige que o agente de tratamento adote medidas de segurança, ocorre que um programa de segurança da informação envolve a gestão de riscos e não a eliminação do risco, já que tal meta é impossível sem a eliminação do próprio tratamento de dados. Dessa forma, em um programa de segurança os riscos são mensurados e são aplicadas medidas para mitigá-los, segundo critérios de gravidade e impacto.

O incidente, apesar de não desejado, é esperado e previsível devendo a área de segurança desenvolver planos que tratem exatamente sobre as medidas e ações a serem tomadas em caso de incidente e planos relacionados a continuidade do negócio após o incidente de segurança.

Portanto, desde que a empresa tenha tomado todas as medidas necessárias para evitar o incidente, segundo as melhores práticas do mercado e tenha também comunicado a ANPD, se for o caso, como veremos mais detalhadamente no tópico próprio, não há que se falar a princípio em imposição de penalidade ou descumprimento da lei.

Ocorreu um incidente

O QUE FAZER?

Quando um incidente de segurança é detectado é muito importante manter a calma e seguir as medidas previamente estabelecidas no plano de resposta a incidentes, elaborado de forma personalizada para a empresa durante o processo de adequação à lei geral de proteção de dados.

No entanto, caso a organização ainda não possua um plano de resposta a incidentes personalizado,

ocorrendo um incidente devem ser tomadas no mínimo as seguintes medidas:

1. **Acionar ou criar uma equipe para gerir e liderar a resposta ao incidente:** no geral a equipe deve ser composta por um profissional de segurança da informação, o encarregado de proteção de dados (DPO), representante do jurídico e representante do setor de comunicação. Em empresas menores no mínimo um profissional de segurança e profissional com conhecimento jurídico e da LGPD;

2. **Fazer a avaliação inicial do incidente:** nessa avaliação deverá ser considerado:

- A extensão do incidente com os setores e dados afetados;
- Gravidade do incidente e risco de dano aos titulares;
- Medidas mitigatórias que podem ser adotadas imediatamente.

3. **Alertas internos sobre o incidente:** alertas internos devem ser realizados para os funcionários, colaboradores e, se afetados, até mesmo fornecedores da empresa, informando-os como proceder, tanto do ponto de vista operacional caso o incidente tenha comprometido a operação, como também com relação a informações que devem ser mantidas sob sigilo até segunda ordem;

4. **Medidas de mitigação imediata:** se possível deve-se tentar isolar a parte do sistema afetado pelo incidente, aplicar patches de correção imediatamente e alterar senhas;

5. **Notificação à ANPD e aos titulares:** se for o caso, como será melhor detalhado no tópico próprio;

6. **Registro detalhado do incidente:** é muito importante o registro detalhado de todo incidente, diferente da avaliação inicial que deve ser feita o mais rápido possível, esses registros podem ser elaborados

no curso de semanas ou até meses, o importante é que documentem de forma detalhada, precisa e minuciosa todas as características do incidente, tanto para ser aproveitado para a implementações de melhorias no sistema como para servir de prova em procedimento administrativo perante a ANPD ou até mesmo procedimento judicial. Os registros devem conter:

- Informações sobre como a evidência do incidente foi obtida;
- Relato detalhado de como o incidente foi detectado bem como quais os profissionais fizeram a identificação do incidente;
- Classificação do incidente – ex: DoS, vírus, *malware*, instalação de *software* não autorizado, acesso não autorizado, cópia não autorizada, *ransomware*, etc;
- Identificação de todos os ativos afetados – ex: *softwares*, *hardwares*, *servidores*, etc;
- **Identificação de todos os dados e informações afetadas:** devendo ser detalhado além da categoria dos dados quais os dados efetivamente afetados dentro da respectiva categoria, ex: categorias - dados pessoais, dados pessoais sensíveis, dados de crianças e adolescentes, dados da organização, dados de fornecedores, etc; dados específicos – nome, rg, cpf, endereço, dados médicos, dados bancários, etc;
- **Informar e detalhar se houve a violação a ambientes físicos:** arquivo físico, prédio onde se encontra o servidor, etc;
- Informar a localização geográfica do incidente;
- Informar e detalhar a falha que permitiu que o incidente ocorresse;
- Identificar o profissional responsável pela elaboração dos registros.

7. **Publicização do incidente:** independentemente da necessidade de notificação à ANPD e aos titulares de dados pessoais afetados, em alguns casos será também necessário publicizar o incidente em função

de prática de governança adotada pela empresa, por requisito regulamentar ou simplesmente em função da magnitude do incidente que, se não informado, pode gerar um dano reputacional maior a organização do que a realização de comunicação pública oficial, elaborada de forma estratégica por profissionais especializados, que demonstre a boa-fé da empresa e as medidas já tomadas para evitar que o incidente se repita;

8. Avaliação e atualização das medidas de segurança: após o incidente é importante realizar uma avaliação detalhada com o objetivo de aprender com a falhas ocorridas e adotar medidas de segurança necessária para que essas falhas não se repitam;

O QUE NÃO FAZER:

1. Desligar ou desconectar os aparelhos: a resposta instintiva de desligar ou desconectar um aparelho imediatamente quando se percebe que o mesmo foi infectado pode trazer mais malefícios que benefícios. Isso porque muitas vezes tal atitude não irá barrar o atacante mas irá afetar as medidas forenses que podem ser adotadas para investigar o incidente e identificar o atacante. Assim, a medida correta é deixar o dispositivo afetado como está e chamar imediatamente profissional de segurança qualificado para lidar com o problema e tomar as salvaguardas necessárias para que as evidências sejam preservadas e o dano não seja pior;

2. Negociar com os atacantes: em razão do enorme prejuízo causado por ataques cibernéticos pode ser tentador e as vezes até mesmo mais barato negociar com os hackers e pagar a quantia exigida para desbloquear o sistema. No entanto, temos que lembrar que estamos falando de criminosos, portanto, o pagamento não irá garantir que o atacante cumprirá com sua palavra. Além disso uma vez que a organização faz um pagamento ela se tornará

conhecida no submundo como uma organização que sede às chantagens o que possivelmente a tornará alvo de mais ataques. Por fim, o pagamento nesses casos pode ser contra políticas de governança da empresa e gerar responsabilidade para os profissionais que tomaram tal decisão, ou até mesmo ser considerado crime em alguns países.

3. **Encobrir o incidente:** incidentes de grande magnitude tendem a ser descobertos, seja por divulgação dos próprios hackers ou por divulgação por fonte interna de forma não autorizada. Assim, é melhor divulgar o incidente de forma controlada, além disso, podem existir diversas obrigações legais, regulamentares ou mesmo organizacionais, estabelecidas em códigos de ética que exigem a divulgação. Por fim, a transparência irá contribuir com a restauração da confiança dos clientes e do mercado.

Notificação à ANPD e aos titulares de dados pessoais

Quando o incidente de segurança envolver dados pessoais deve-se analisar a necessidade de notificação à ANPD. O art. 48 da LGPD determina que o controlador dos dados deverá notificar a autoridade quando o incidente for capaz de acarretar risco ou dano relevante aos titulares.

A lei não especifica o que seria dano relevante, porém considerando documentação e resoluções publicadas pela ANPD podemos considerar alguns critérios, como por exemplo:

1. Tratamento de dados pessoais em larga escala;
2. Tratamento de dados sensíveis;
3. Tratamento de dados de crianças e adolescentes ou idosos;

4. Tratamento de dados que impliquem fornecimento ou negação de um serviço;
5. Tratamento de dados que podem acarretar o cometimento de fraudes financeiras;
6. Tratamento de dados que impliquem fornecimento ou negação de um serviço;
7. Se os dados afetados estavam protegidos por algum sistema de criptografia;

A lei também não estabeleceu prazo para a comunicação do incidente de segurança, estabelecendo apenas no §1º do art. 48 que a comunicação deverá ser feita em prazo razoável, porém a ANPD em comunicado divulgado em seu site oficial determinou o prazo de 2 dias úteis a contar da detecção do incidente.

Recomenda-se que a comunicação seja feita através do preenchimento de formulário oficial divulgado também no site da própria ANPD. Note-se que o prazo para a comunicação é bem curto, assim não se espera que o controlador já tenha todos os detalhes do incidente, mas sim que ele informe o mais rápido possível as descobertas iniciais, sendo possível prestar outros esclarecimentos, se for o caso, no prazo de 30 dias corridos a contar da primeira comunicação.

Os titulares de dados pessoais em caso de risco relevante também devem ser comunicados, sendo que a ANPD recomenda a comunicação no prazo de 2 dias úteis. Destaca-se que a comunicação aos titulares vai de encontro ao princípio da prevenção, já que uma vez comunicados os titulares podem tomar medidas para mitigar o dano, como por exemplo trocas de senhas pessoais.

Para mais detalhes sobre este e outros assuntos relacionados com cuidados com os dados pessoais na Internet, consulte os demais materiais, disponíveis no site do escritório Mascarello Haus. A plataforma apresenta uma série de materiais focados nas empresas e nas diversas partes interessadas.



Camila Catanho
Advogada especialista em direito digital | Consultora em proteção de dados pessoais | LGPD | DPO | Palestrante de LGPD | Treinamento corporativo em proteção de dados

Miratáira Haus
Advogada, Professora e Consultora | Esp. em Direito Digital e Compliance, Direito do Trabalho e Previdenciário | DPO Certificada EXIN.



Mascarello Haus

A Mascarello Haus Advocacia e Consultoria Jurídica, desde de 2016, presta serviços consultivos e de assessoramento nas áreas do Direito Civil, Empresarial, do Trabalho e Previdenciário.

Atualmente, é um escritório dedicado a entender às necessidades e riscos, em fomento da conformidade e boas práticas relacionadas a regulação do mercado, direcionado ao Compliance nas mais diversas áreas, em especial à Proteção de Dados. Por meio de equipe multidisciplinar, orienta e desenvolve estratégias que atendam aspectos regulamentares, de governança corporativa e de segurança da informação, em respeito à metodologia aplicável a cada segmento.

De maneira proativa também atua nas organizações da sociedade civil em projetos sociais e Advocacia Pro Bono.

MASCARELLO HAUS
CONSULTORIA E ASSESSORIA JURÍDICA

mascarellohaus.adv.br

mascarellohausadvocacia

49 98822 0982

contato@mascarellohaus.adv.br

Rua Coronel Alberto Schmidt, 10 • Edifício Laura, 1º Andar, Sala 5, • Centro • Videira • SC